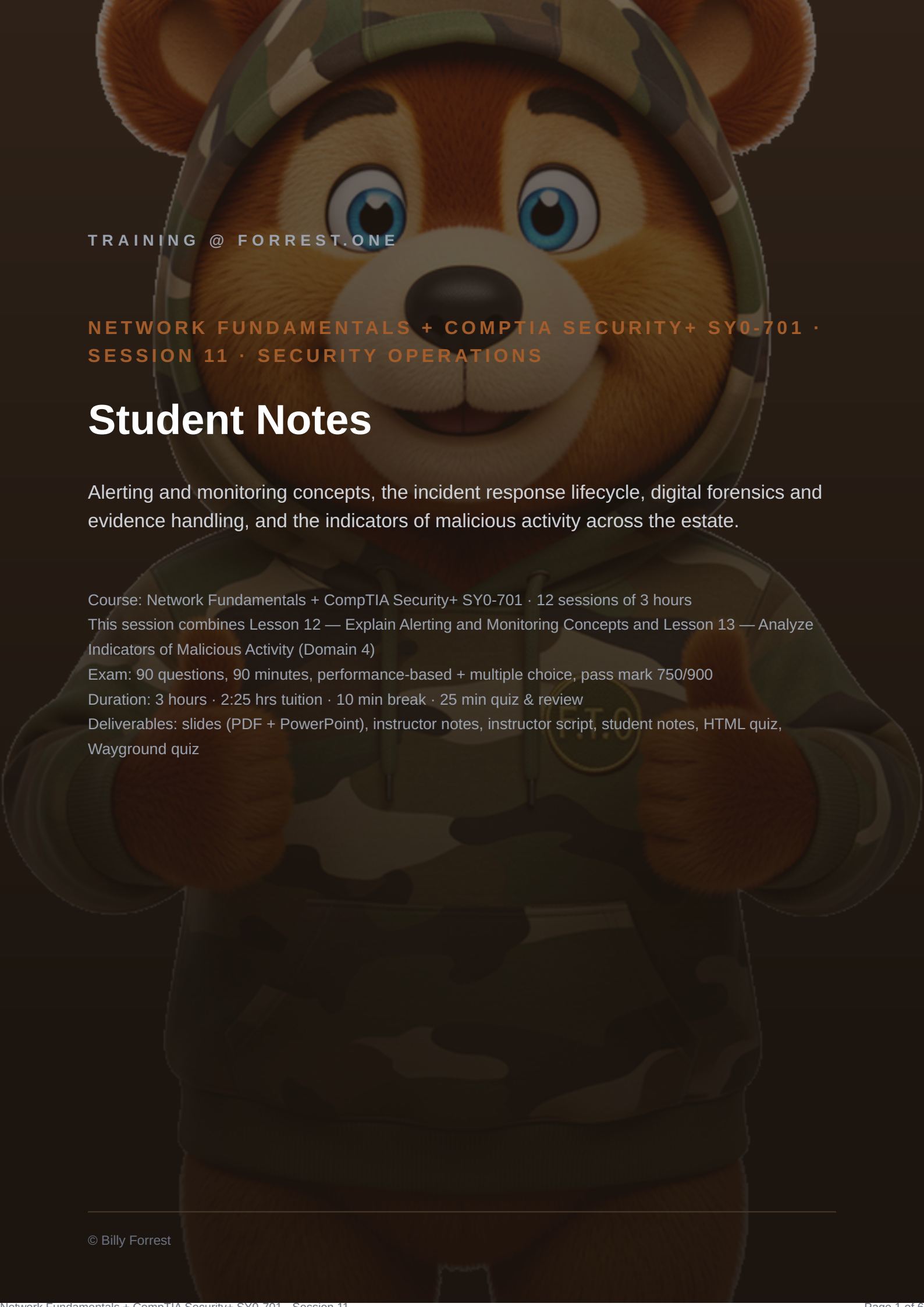




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 11 · SECURITY OPERATIONS

Student Notes

Alerting and monitoring concepts, the incident response lifecycle, digital forensics and evidence handling, and the indicators of malicious activity across the estate.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lesson 12 — Explain Alerting and Monitoring Concepts and Lesson 13 — Analyze Indicators of Malicious Activity (Domain 4)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Security Operations, Monitoring & Forensics

Your revision guide for Session 11 (Lessons 12 to 13 · Domain 4, Security Operations, 28% of the exam, the largest domain). Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. The session runs in six chapters: monitoring and network security devices, endpoint and data controls, identity and automation, incident response, threat hunting and forensic evidence, then logs and consolidation. Domain 4 is scenario-heavy and rewards order-of-operations thinking: monitor, control, respond, hunt, investigate.

Key terms

Term	Definition
Packet filtering firewall	Network layer filtering on source, destination, protocol and port, with no state
Stateful inspection	Keeps a state table and judges each packet by its conversation
NGFW	Next-generation firewall: application awareness, deep packet inspection, intrusion prevention
WAF	Web application firewall: layer 7, reads HTTP and HTTPS requests and blocks web attacks
DMZ	Demilitarized zone: a segmented zone between the internet and the internal network
IDS	Intrusion detection system: passive, detects and alerts only
IPS	Intrusion prevention system: inline, drops packets, blocks addresses, resets connections
Signature-based detection	Matches traffic against a database of known attack patterns
Anomaly-based detection	Baselines normal activity and alerts on deviation
DNS filtering	Blocks malicious or policy-breaking domains at the name resolution query
DLP	Data loss prevention: monitors, detects and controls movement of sensitive data
NAC	Network access control: posture check before a device joins the network
EDR	Endpoint detection and response: behaviour-based endpoint monitoring and response
XDR	Extended detection and response: correlates endpoint, network and cloud data
IAM	Identity and access management: controls who has access to what
User lifecycle	Onboarding, role changes, and offboarding (deprovisioning)

Term	Definition
SSO	Single sign-on: one credential, many systems, and a single point of failure
Federation	Trust between an identity provider and a service provider, proven by a token
MFA	Multifactor authentication: two or more different factor categories
TOTP	Time-based one-time password, as generated by an authenticator application
PAM	Privileged access management: just-in-time access, session recording, vaulting
Orchestration	Automated tasks coordinated into one workflow, in sequence
IR lifecycle	Preparation, detection and analysis, containment, eradication, recovery, lessons learned
Incident classification	Type: unauthorised access, malware, denial of service, data breach
Severity	Low, medium, high, critical, which drives response urgency
Tabletop exercise	Discussion-based walkthrough of a scenario, low cost, exposes plan gaps
Functional exercise	Hands-on testing of specific capabilities with real tools
Full-scale exercise	Multi-team, all roles performed, end to end
After-action review	What worked, what was difficult, what changes; findings feed the plan
Threat hunting	Proactive searching for threats that the alerts missed
Indicator sweeping	Searching the estate for known indicators of compromise
Root cause analysis	Finding the underlying cause of an incident so it cannot recur
Write blocker	Prevents any change to the original storage device during examination
Forensic imaging	Bit-for-bit copy, including deleted and hidden data
Hash verification	Comparing hashes of the original and the image to prove nothing changed
Chain of custody	The documented history of evidence handling
Order of volatility	Capture the most volatile data first: registers, memory, then disk
Memory forensics	Analysing RAM: running processes, open connections, malware remnants
Metadata analysis	Creation dates, authorship, modification history
SIEM	Aggregates and correlates monitoring sources into one view
Retention policy	How long logs are kept, archived and then deleted
C2 beacon	Small, regular connections to a command-and-control host
Impossible travel	Logins from locations too far apart in time to be real

Core concepts

Chapter 1 · Monitoring and network security devices

Firewalls progress by what they can see: packet filtering matches addresses, ports and protocol with no state; stateful inspection adds the conversation; the next-generation firewall adds application awareness, deep packet inspection and intrusion prevention. Rules need specific creation, change control and regular review, and firewalls enforce segmentation including the DMZ. The web application firewall works at layer 7, reading HTTP and HTTPS requests to block injection and cross-site scripting. An IDS detects and alerts; an IPS drops, blocks and resets. Detection is either signature-based (known threats, blind to novelty) or anomaly-based (baselines, unknown threats, more false positives), and tuning is what keeps both useful. Host logs matter too: the xrdp log on a Kali box records every RDP attempt, and a run of failures followed by a success from one address means brute force that worked.

Chapter 2 · Endpoint and data controls

Domain Name System filtering intercepts the name resolution query and checks it against a blocklist or allowlist, denying the request before a connection exists. Data loss prevention watches data in motion (network) and at rest or in use (endpoint), matching content, context and user action, with actions that alert, block or encrypt. Network access control checks posture (antivirus, updates, credentials) before a device joins, then denies or quarantines anything non-compliant. Endpoint detection and response watches behaviour and telemetry, which is how it catches zero-day and advanced persistent threats that signature antivirus misses. Extended detection and response correlates endpoint, network and cloud data, and the alert investigation workflow runs triage, analysis, contextualisation, response planning, then remediation and recovery, with automated responses such as isolating an endpoint or revoking credentials.

Chapter 3 · Identity, access and automation

Identity and access management provisions accounts, modifies them on role change and deactivates them on exit; late offboarding is a common audit finding. Single sign-on is convenient and a single point of failure, so pair it with multifactor authentication. Directory services hold the identities (Active Directory, LDAP, cloud directories); federation links identity systems with trust and tokens; identity governance runs the access reviews. Multifactor authentication combines different factor categories (know, have, are), and two passwords are still one factor. Privileged access management adds just-in-time access, session recording and password vaulting, so every privileged use is attributable. Automation covers patching, provisioning and incident response playbooks, while orchestration chains those tasks into one workflow. Guardrails are mandatory: test changes, restrict who edits scripts, log every action, and keep human oversight for judgement, exceptions and ethics.

Chapter 4 · Incident response

The four phases, in order: preparation (policy, tools, written plan, trained people, rehearsals); detection and analysis (identify, scope, grade); containment, eradication and recovery (isolate, remove the cause, restore from validated backups); then lessons learned. Containment and eradication are different jobs, and containment preserves evidence but can alert the adversary. Classification (unauthorised access, malware, denial of service, data breach) and severity (low to critical) drive urgency, while named roles remove hesitation: handlers, management, legal, communications. Preparation is tested by tabletop, functional and

full-scale exercises, each testing more of the plan than the last. Responder training and general staff awareness are ongoing, and the after-action review feeds findings back into the plan.

Chapter 5 · Threat hunting and forensic evidence

Threat hunting assumes an attacker is already inside. Hypothesis-driven investigation tests an idea with targeted searches, and indicator sweeping searches the estate for known indicators of compromise (addresses, file hashes, domains); findings sharpen the detection rules. Root cause analysis runs in order: identify the problem, gather data, analyse for patterns, identify the root causes (configuration, behaviour or vulnerability), develop and implement solutions, then monitor their effect. Forensics collects and preserves evidence: collection from computers, mobile devices and network systems; write blockers so nothing changes; forensic imaging bit by bit, including deleted and hidden data; hash verification between original and image; and volatile data before disk. The chain of custody records every handler, and an unbroken chain is what makes evidence admissible; authorisation (warrant or consent) and privacy law (GDPR, ECPA) shape collection, and evidence must be organised, documented and reported.

Chapter 6 · Logs, investigation and consolidation

Security logs record logins and privilege changes; system logs cover boot, hardware and errors; application logs capture errors, interactions and transactions; network device logs cover traffic, status and configuration change; firewall logs record allowed and denied traffic. Collection feeds centralisation into a SIEM, where correlation turns separate events into one story, and retention policy decides how long logs are kept, archived and deleted, set by regulation and investigative need. Beyond logs sit network capture, memory forensics (running processes, open connections, malware remnants) and metadata analysis (creation dates, authorship, modification history). Indicators close the session: malware (virus, worm, Trojan, ransomware, spyware, rootkit, botnet); network (port scanning, data exfiltration, command-and-control beaconing); application (injection probes, phishing email); and behavioural (privilege escalation, impossible travel, data volume spikes).

Practical cautions

- Do not assume a plain firewall sees the application. Only a next-generation firewall does.
- Do not confuse detection with prevention. An IDS alerts; an IPS acts.
- Do not leave detection untuned. Anomaly-based detection floods, and alert fatigue hides real incidents.
- Do not start response at containment. Preparation comes first.
- Do not treat every incident alike. Classify it and grade its severity.
- Do not skip the after-action review. Lessons learned prevent recurrence.
- Do not analyse the original drive. Image and hash first, then work on the copy.
- Do not collect evidence without authorisation. A warrant or consent comes first.
- Do not ignore the order of volatility. Memory will not wait for the disk.
- Do not celebrate 'service restored'. Verify and monitor.
- Do not set retention by convenience. You cannot investigate what you never kept.
- Do not let automation make the judgement call. Keep a human on exceptions and ethics.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 11

- Sequencing is the exam skill: the IR phases and the order of volatility.
- Learn what each firewall generation can see. Application awareness is the NGFW line.
- Know the control-to-layer match: firewall and NGFW, NAC, DLP, EDR, XDR.
- Alert fatigue, baselines and tuning are common monitoring items.
- Signature against anomaly detection appears as a comparison question.
- Identity items are scenario-heavy: lifecycle, SSO and federation, MFA factors, PAM.
- Automation questions reward knowing what should stay with a human.
- Chain of custody and order of volatility are guaranteed items.
- Authorisation (warrant or consent) and write blockers appear in forensic scenarios.
- Retention is examined as a compliance and investigation issue.
- Indicators are scenario-based: read the pattern, name the indicator.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 4.
- NIST SP 800-61, incident handling guide.
- NIST SP 800-86, forensic techniques and guidelines.
- NIST SP 800-207, Zero Trust Architecture, for the identity material.